

ISYS90090
Cybersecurity
Management

WEEK 2

ATIF AHMAD



The background of the image is a complex marbled pattern. It features swirling, organic shapes in various shades of brown, from light tan and beige to deep, dark chocolate and near-black tones. There are also some cooler, muted blue and greyish-green accents interspersed within the brown swirls, creating a rich, textured visual effect.

**If you think technology can
solve your security problems, then
you don't understand the problems
and you don't understand the
technology.**

Mocah
Bruce Schneier

This Week in Cybersecurity Management



- ▶ Step 1: Study Canvas Module 2
- ▶ Step 2: Read the prescribed textbook pages 27 to 34 on “Need for Information Security”
- ▶ Optional Step 3: Answer discussion questions on Canvas, and chat with peers
- ▶ Step 4: Attend workshop
- ▶ Optional Step 5: Continue discussion with peers on Canvas

This week's workshop



- ▶ **Part A:** Quiz
- ▶ **Part B:** Q&A session on this week's content
- ▶ **Part C:** Role play activity
 - ▶ Read Fitzgerald (2007)
 - ▶ Class divided into three groups (CEOs, CIOs, CISOs)
 - ▶ Answer and debate questions on role of cybersecurity in the firm

Please Turn up to the Assigned Workshop to take the Quiz

Intended Learning Objectives

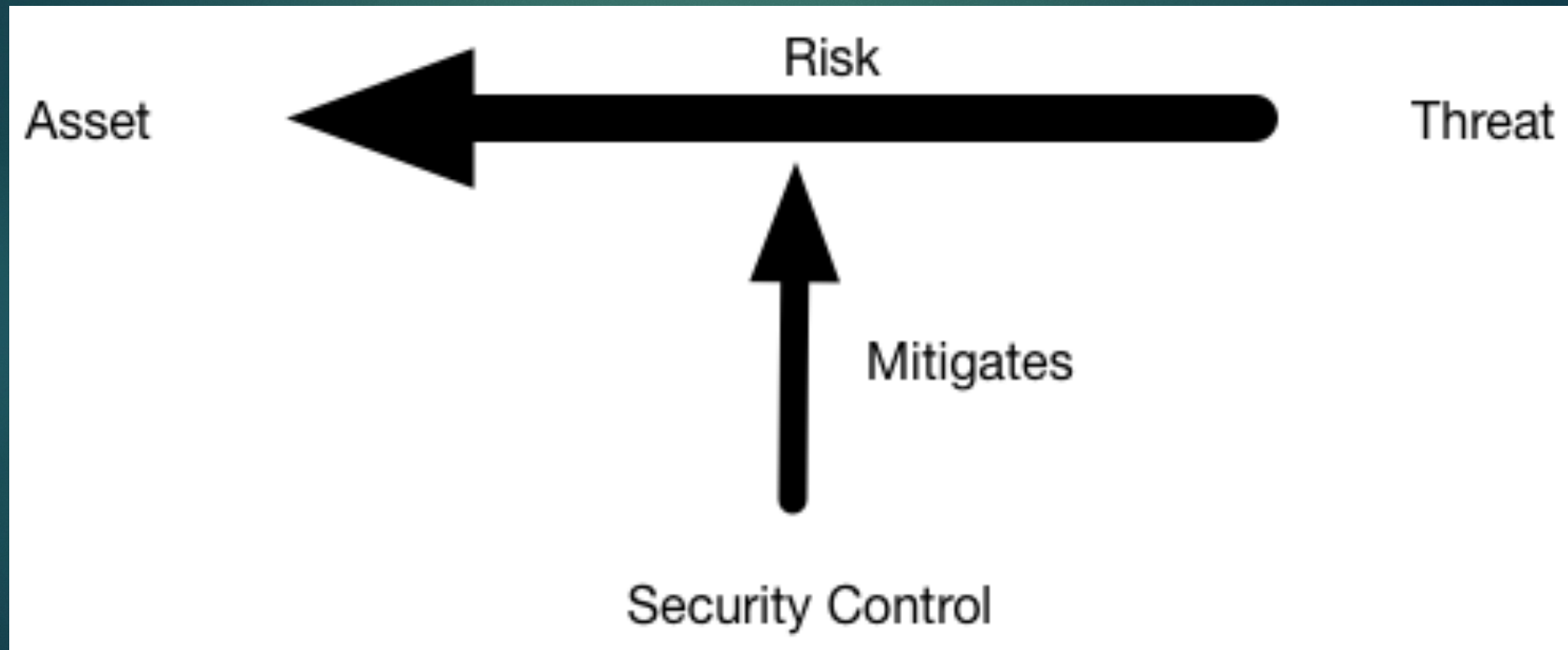


Understand the significance of the cybersecurity triplet model in addressing cybersecurity challenges

Identify and describe the role of information security and protecting organisational information resources

Understand the responsibilities and key functions of a chief information security officer within an organisation.

The Triplet Model: A Model of Security Science



Canvas Discussion: Triplet Model

- Describe the following relationships in the triplet model using your own words:
 - Asset vs threat
 - Risk vs Control
 - Asset, threat, risk and control
- How can we redefine information security in the context of the relationships between assets, threats and controls? Discuss the following definition with your peers, do you agree with its wording? If not, what would you change?
- ▶ *Information security management is a process by which (formal, informal and technological) controls are applied to reduce the risk exposure arising from a suite of risk scenarios where specific threat actors exploit specific vulnerabilities in specific assets to create an impact - to a level acceptable to the organisation*



How do we define the state of being secure?

CONFIDENTIALITY

INTEGRITY

AVAILABILITY

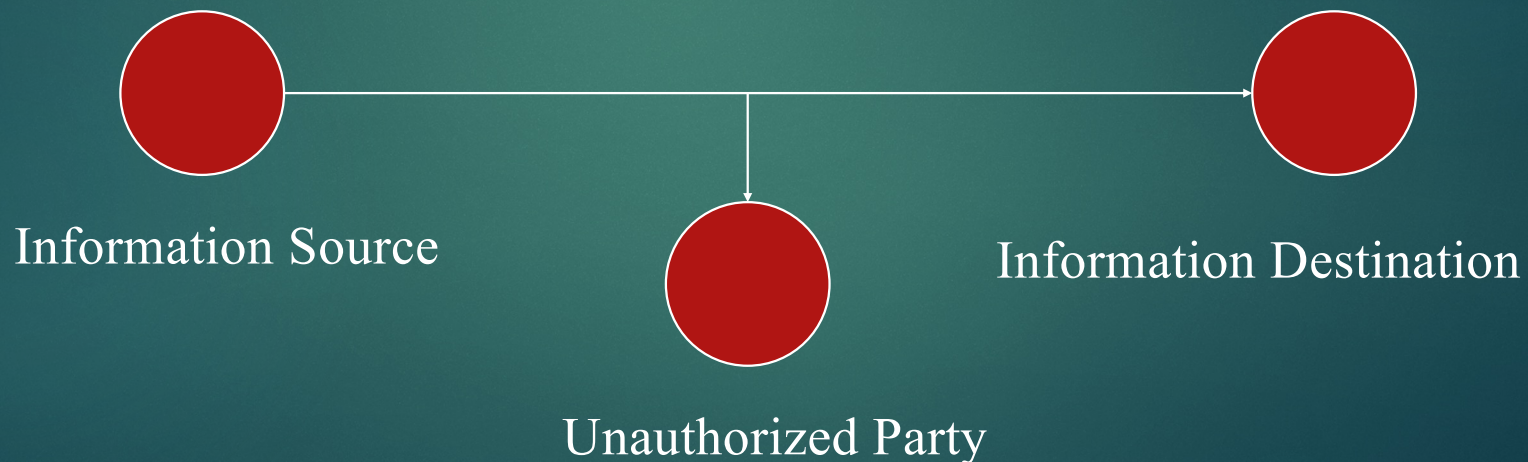


Confidentiality

REQUIRES THAT THE INFORMATION IN A COMPUTER
SYSTEM AND TRANSMITTED INFORMATION BE
ACCESSIBLE ONLY FOR READING BY AUTHORIZED
PARTIES

Confidentiality Attack (Interception)

An unauthorized party gains access to an asset



Confidentiality Attacks



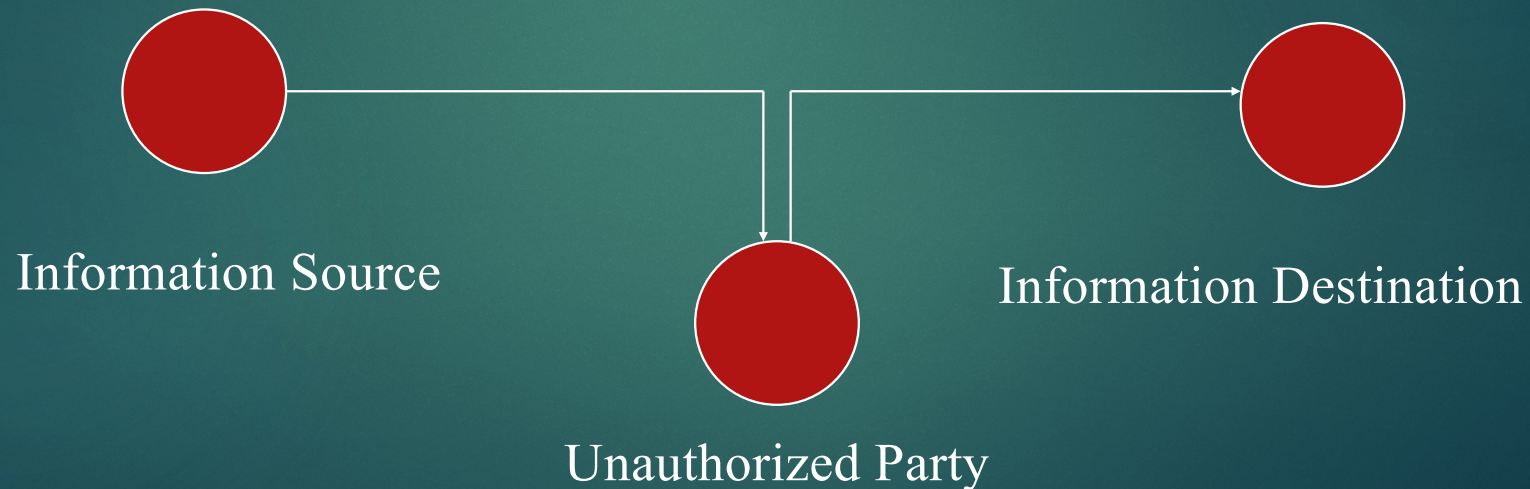
- Wiretapping to capture data in a network
- Illicit copying of files or programs

Integrity

REQUIRES THAT COMPUTER SYSTEM ASSETS AND
TRANSMITTED INFORMATION BE CAPABLE OF
MODIFICATION ONLY BY AUTHORIZED PARTIES

Integrity Attack (Modification)

An unauthorized party not only gains access to but tampers with an asset



Integrity Attacks



- Changing values in a data file
- Altering a program so that it performs differently
- Modifying the content of messages being transmitted in a network

Availability

REQUIRES THAT COMPUTER SYSTEM ASSETS BE
AVAILABLE TO AUTHORIZED PARTIES WHEN NEEDED

Availability (Interruption or Destruction)

An asset of the information source is
destroyed or becomes unavailable or
unusable



Availability Attacks

- ▶ Destroying a piece of hardware
- ▶ Cutting a communication line
- ▶ Disabling a file management system



CIA Attacks



- ▶ Confidentiality Attack [Interception]
 - ▶ Unauthorized party gets access to information
- ▶ Integrity Attack [Modification]
 - ▶ Unauthorized party gets access to and tampers with transmission
- ▶ Availability Attack [Interruption / Destruction]
 - ▶ Asset gets destroyed or becomes unusable



What countermeasures can we
use to control risk exposure?



Categories of Information Security Controls

- ▶ Formal Controls
- ▶ Informal Controls
- ▶ Technological Controls



Role of Information Security in Organisations



- ▶ Role 1: Protects ability to function
- ▶ Role 2: Enables safe operation of applications implemented on its IT systems
- ▶ Role 3: Protects data, information and knowledge the organisation collects and uses
- ▶ Role 4: Safeguards technology assets in organisations

Canvas Discussion: Role of Information Security in Organisations



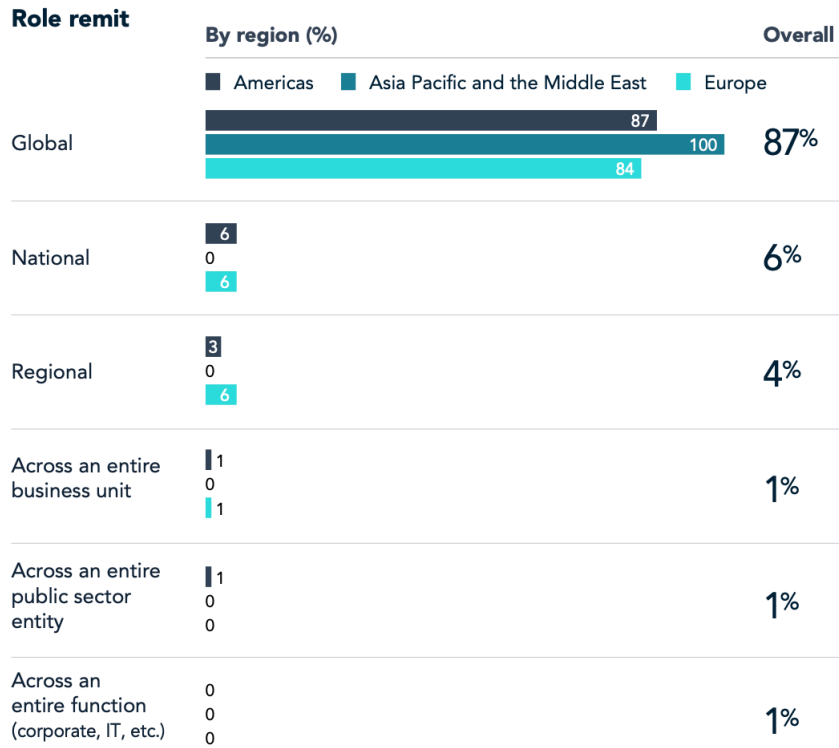
- Role 1 of information security focuses on protecting the ability to function. *How does addressing a range of security risks contribute to maintaining the continuity of business operations? What are some examples of specific security risks that can impact business operations?*
- Role 2 emphasises creating a secure environment for applications implemented on IT systems. *Why is this role significant? What about third party applications?*
- Role 3 involves protecting the data, information, and knowledge collected and used by an organisation. *Why is safeguarding this data a critical responsibility of information security? What are some examples of sensitive information that organisations need to protect?*
- Role 4 emphasises safeguarding technology assets in organisations. *Why is protecting technology infrastructure such as computing systems and networks important to organisations? What are some examples of technology threats that organisations may face*



What is the role of the CISO?

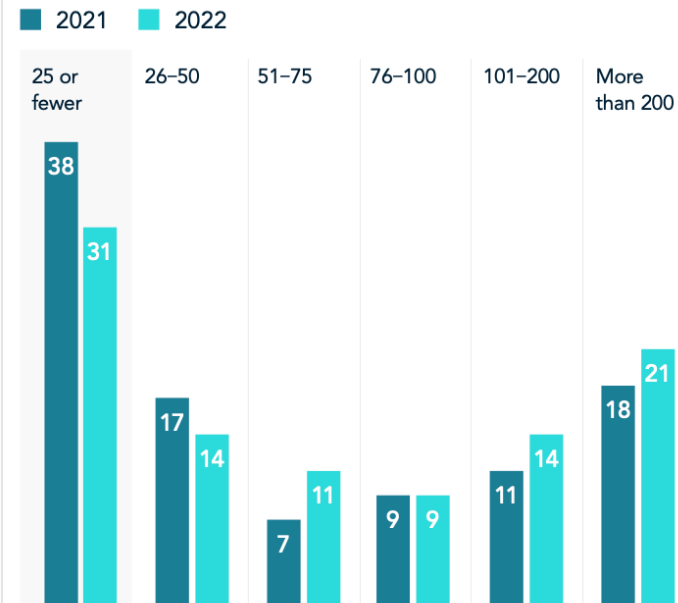


CISO Survey – Respondent breakdown



Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

Number of team members (%)



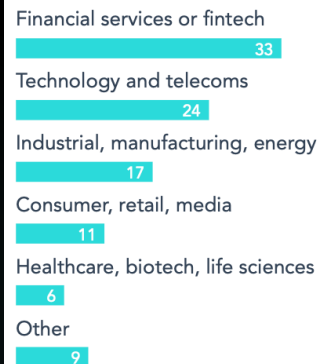
Sources: Heidrick & Struggles' global chief information security officer (CISO) survey, 2021, n = 354 information security professionals
Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

CISO 101: Which industries have CISOs?



Company information

Company industry (%)



Company revenue (%)



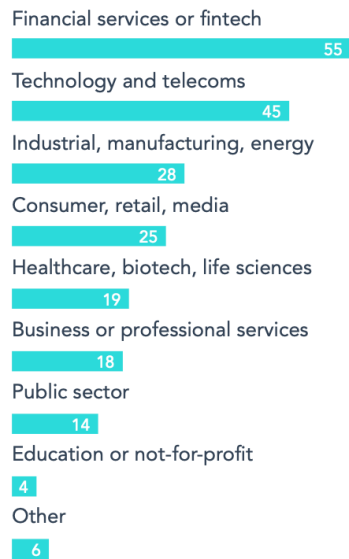
Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

CISO 101: CISO Career Path

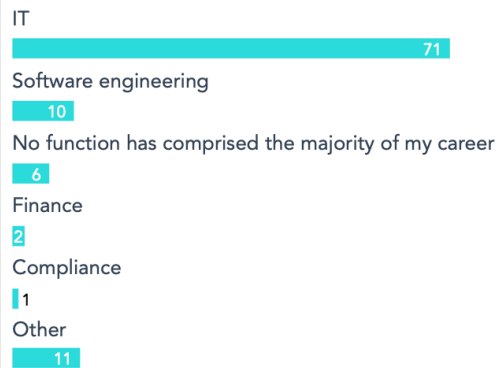


General experience

Sector experience (%)



Main function of career (%)



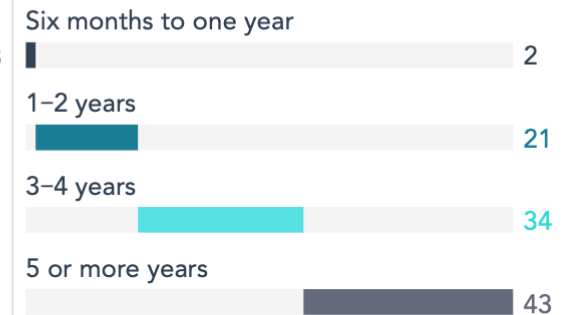
Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

Previous role experience

Prior role or function (%)



Tenure of previous role (%)

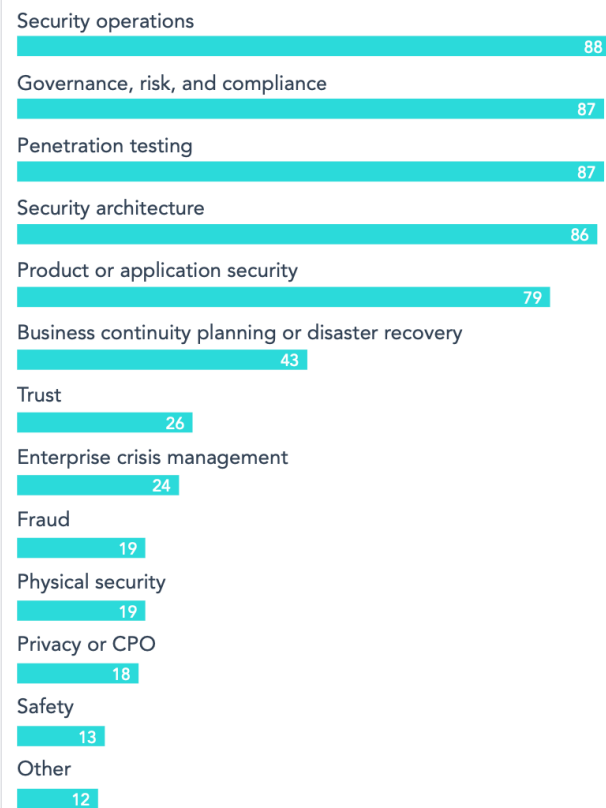


Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

CISO 101: The Primary Role of a CISO

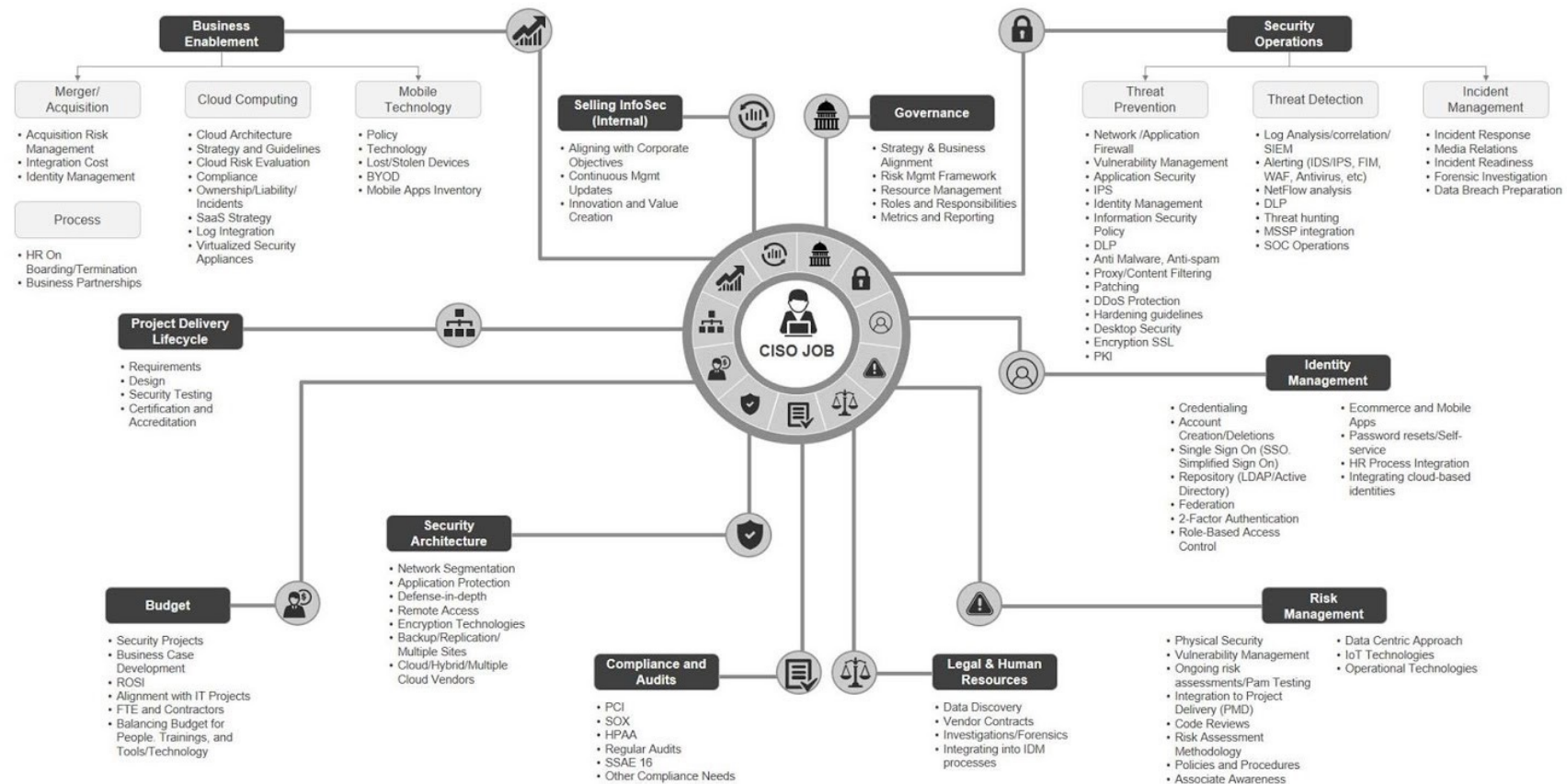


Functional areas that report to the CISO (%)



Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

CISO Mind Map



Source: <http://rafeeqrehman.com/2015/05/17/the-latest-2015-ciso-mindmap-is-here/>

An Overview of The Responsibilities and Ever Expanding Role of The CISO

CISO 101: Most Significant Cyber Risks

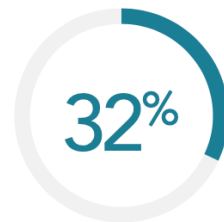


Most significant cyber risks

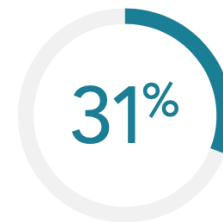
Ransomware attacks



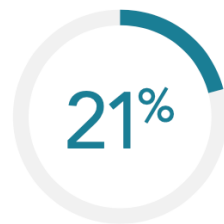
Insider threats



Nation/state attacks



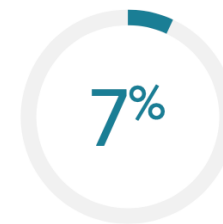
Malware attacks



Malware-free attacks



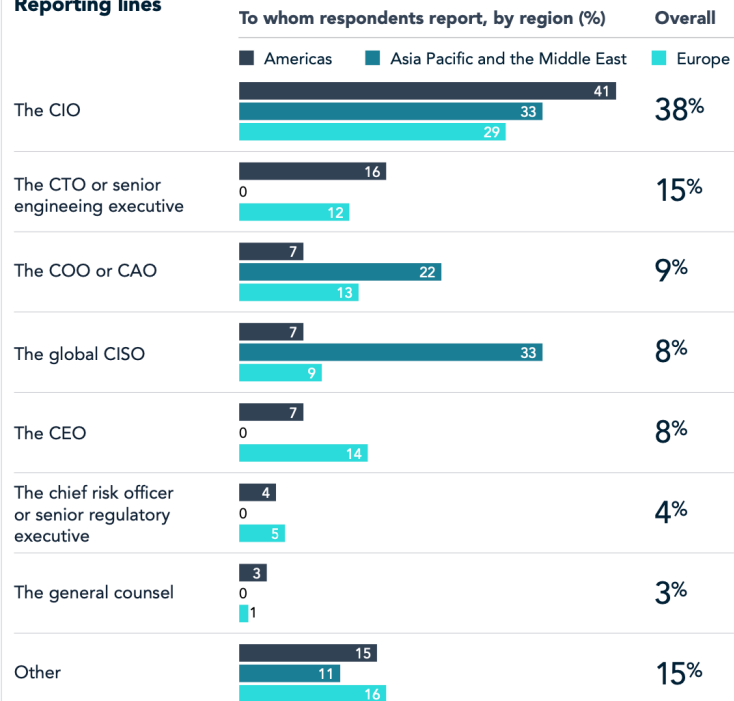
Other



Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

CISO 101: Reporting to the Leadership

Reporting lines

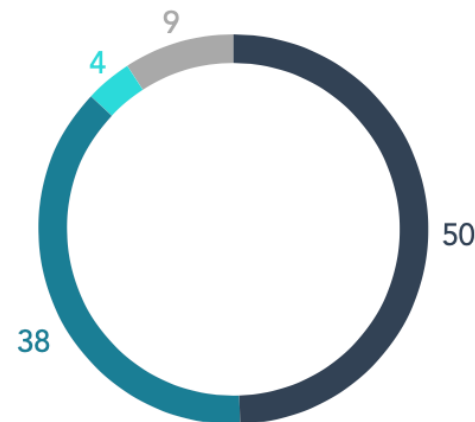


Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

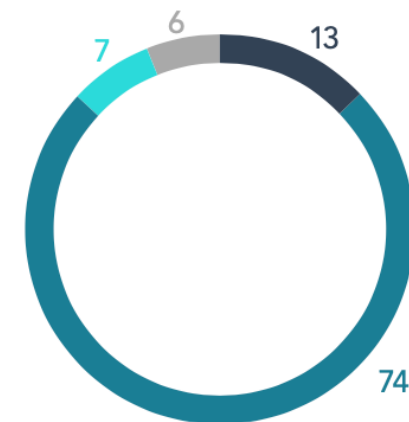
Board presentation

■ Annually ■ Quarterly ■ Monthly ■ Ad hoc

Frequency at which respondents present to the full board, if at all (%)



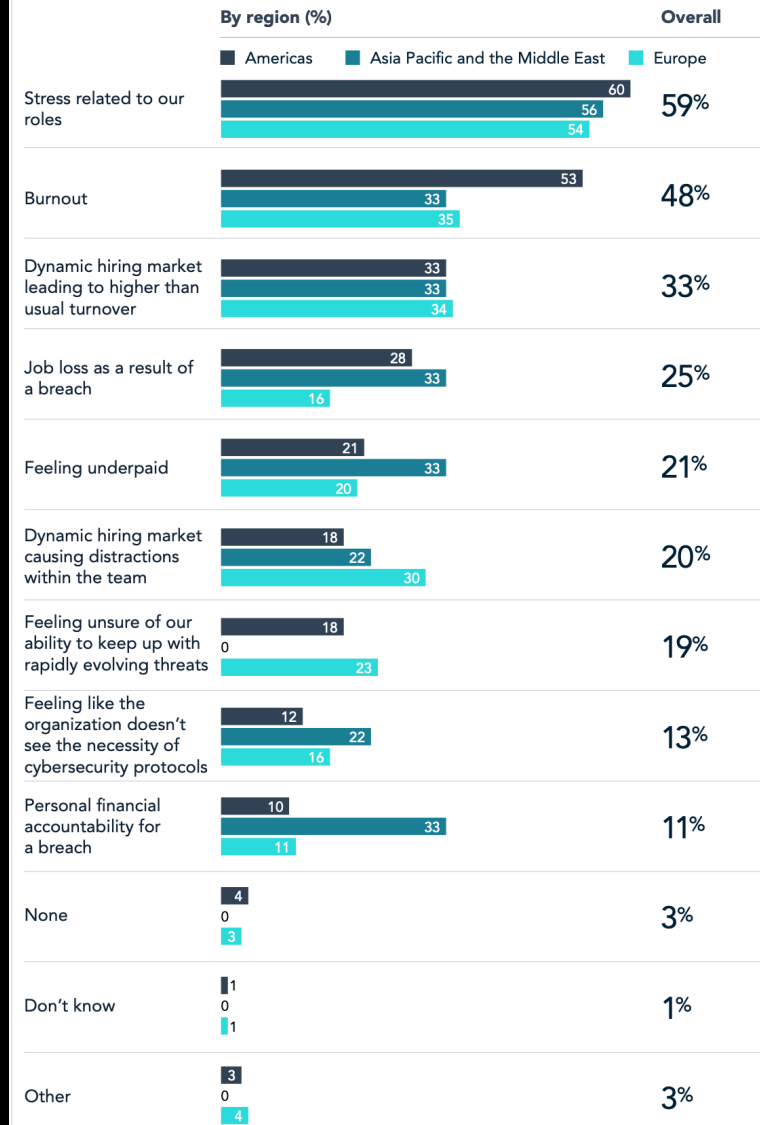
Frequency at which respondents present to a board committee, if at all (%)



Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 288 information security professionals

Personal Risks

Most significant personal risks relating to role



CISO: 101: Where to Next?



Source: Heidrick & Struggles' global chief information security officer (CISO) survey, 2022, n = 327 information security professionals

Results of a Global Survey on CISOs



01

Over 90 percent of CISOs hope to improve the alignment between the security organisation and the business, yet nearly half (46 percent) fear the inability to accomplish that alignment. This misalignment between the security goals and organisational objectives results in poor cybersecurity maturity.

02

Only 22 percent of respondents work in an organisation where the CISO reports directly to the CEO, while 40 percent still report to the CIO. This has the potential to reduce the strategic impact and independence of their decisions.

03

Only 18 percent of CISOs have held managerial roles before moving into security organisation. Since most are technologists by training and trade, the individuals will be more focused on operations, tactical moves and managing compliance, rather than focusing on the maturity of the cyber-security graph of the organisation.

These challenges pose an important question for decision-makers, 'Should my enterprise hire a resource to manage information security, or would it be more prudent to opt for a team of external experts as a service that can navigate their way through this complex and evolving role?'

Canvas Discussion: The global Chief Information Security Officer

- ▶ Here are some questions to discuss about the global role of CISOs:
- ▶ 1. What factors are likely to derail CISO attempts to align cybersecurity to the business?
- ▶ 2. Why do you think the percentage of CISOs that report to CEOs is so low?
- ▶ 3. Why do you think only 18% of CISOs have previously held managerial roles?
- ▶ 4. What are the main tasks / responsibilities of a CISO?

Question



What are the three types of strategic cyber-risks faced by organizations?

Q&A

